
NONPROFIT AI RESOURCE SERIES · LANE 1: CONSIDERING AI

AI Security for Nonprofits

What actually happens to your data

Mandy Hathaway Consulting · mandyhathaway.com · AI Ethics & Technology Consulting

The security concern comes up in almost every conversation about AI in the nonprofit sector, and it should. You work with people's medical histories, housing records, employment files, and case notes. You hold information that, in the wrong hands, could harm the people you serve. That concern is not unfounded, and it does not go away just because an AI tool has a privacy policy.

This guide does not tell you that AI is safe. It tells you what is actually happening when data moves through an AI tool, where the real risks are, and what you can do to protect your clients and your organization.

The question is not whether AI tools have security risks. Everything digital does. The question is

whether you understand them well enough to make a deliberate choice.

What happens when you use a cloud AI tool

When a staff member types something into a cloud-based AI tool, that text leaves your building. It travels over the internet to a server operated by the AI company, gets processed, and a response comes back. At minimum, the AI company's infrastructure has handled your text.

What happens after that depends on the tool and the terms of service you agreed to. There are three things that can happen to your data once it reaches that server:

1 It is processed and discarded.

Some enterprise tools process your input to generate a response and do not retain it afterward. This is the most protective option and is standard in paid enterprise plans from major vendors.

2 It is stored temporarily.

Many tools retain conversation history for a period of time. This is usually to power features like chat history or to let you return to a previous conversation. That stored data sits on the vendor's servers and is subject to their security practices.

3 It is used to train or improve the model.

Some free tools, particularly consumer-facing ones, include language in their terms of service allowing them to use your inputs to improve their AI. This is the scenario with the most significant privacy implications for nonprofits.

IMPORTANT DISTINCTION

Free consumer tools and paid enterprise tools often have very different data handling policies. The free version of a tool may use your inputs for

training. The paid enterprise version of the same tool may not. Always check the terms for the specific plan your organization is using, not just the company's general privacy page.

What you should never put into an AI tool

Regardless of which tool you use or what their policies say, some categories of information should never go into an external AI system. If any of the following appears in what you are typing or uploading, remove it first.

- × Client names combined with any service detail, diagnosis, or case information
- × Social Security numbers, Medicaid IDs, or any government identification numbers
- × Medical or psychiatric records, diagnoses, or treatment notes
- × Housing status, address, or residential placement information
- × Income, benefits, or financial account information
- × Immigration status
- × Any information a client shared under an expectation of confidentiality
- × Login credentials, passwords, or internal system access information
- × Donor personal information beyond what is already public
- × Proprietary grant application content before submission

This does not mean you cannot use AI for case-related work. It means you need to work with anonymized or generalized versions of information. Describing a situation in general terms, "a client who needs supported employment and has a recent gap in housing stability," gives an AI tool enough context to be helpful without putting any individual at risk.

What "training on your data" actually means

You may have heard that AI companies train on user data and worry that a client's information could end up influencing the model and appearing in someone else's response. This is worth understanding clearly, because the risk is real but different from how it is often described.

When an AI company uses conversation data for training, that text gets processed mathematically to adjust the model's behavior over time. It does not get stored in a retrievable database where someone could search for it. A specific client's name or case note is extremely unlikely to be reproduced verbatim in a future response.

The actual risk is subtler: your organization's data patterns, language, and context could influence model behavior in ways that are hard to predict or trace. For most nonprofits this is a lower-stakes concern than the more direct risks of data breach or improper storage. But for organizations subject to HIPAA or state-level data protection requirements, any use of protected information in external AI systems should go through your compliance process regardless of training risk.

Five things to do before using any AI tool organizationally

- 1 Read the data processing terms, not just the privacy policy.**
Look specifically for language about training, data retention, and whether your organization's data is used to improve the model. These terms are often in the "enterprise" or "business" section of the documentation.
- 2 Ask whether a data processing agreement (DPA) is available.**
Enterprise vendors typically offer a DPA that specifies exactly how your data is handled. If a vendor cannot provide one, that is relevant information about their suitability for your organization.

3 Decide what categories of information staff are permitted to use with AI tools.

This does not require a lengthy policy document to start. A one-page list of what is and is not acceptable is enough to give staff guidance and reduce your risk immediately.

4 Check whether your existing compliance obligations apply.

If you handle health information, you may have HIPAA obligations. If you serve immigrants, you have additional sensitivity considerations. Know which frameworks apply to your organization before expanding AI use.

5 Designate someone to own this.

Security decisions made ad hoc by individual staff members produce inconsistent results. One person does not need to become an AI expert, but someone should be the point of contact for questions and the person who reviews new tools before they get adopted.

QUESTIONS TO ASK ANY AI VENDOR

Do you use customer data to train your models, and can I opt out?

How long do you retain conversation or input data?

Do you offer a data processing agreement for nonprofit or enterprise accounts?

Where are your servers located, and are they subject to US data protection law?

What happens to our data if we cancel our account?

If something goes wrong

Most AI security incidents at nonprofits are not dramatic breaches. They are staff members inadvertently sharing more than they should, or using a free consumer tool that was not approved for organizational use. The more common failure mode is policy drift, not a cyberattack.

If you discover that protected client information was sent to an external AI tool, treat it the same way you would any data incident. Document what happened, assess what information was involved, check whether your breach notification obligations apply, and use it as the prompt to put clearer guidelines in place.

The goal is not a perfect record. The goal is a culture where staff know what the expectations are and feel comfortable raising questions before something goes wrong rather than after.

Mandy Hathaway

AI Ethics & Technology Consulting for Nonprofits

mandyhathaway.com · [Book a call](#)